

Industrial Network Security

1st Andrey Sysoev
*Hamm-Lippstadt University
of Applied Sciences (HSHL)*
Lippstadt, Germany
andrey.sysoev@stud.hshl.de

2nd Sadim Rahman Badhan
*Hamm-Lippstadt University
of Applied Sciences (HSHL)*
Lippstadt, Germany
sadim-rahman.badhan@stud.hshl.de

3rd Md Mamun Hossain
*Hamm-Lippstadt University
of Applied Sciences (HSHL)*
Lippstadt, Germany
md-mamun.hossain@stud.hshl.de

4th Umut Karakaya
*Hamm-Lippstadt University
of Applied Sciences (HSHL)*
Lippstadt, Germany
umut-faruk.karakaya@stud.hshl.de

Abstract—Today, industrial organizations are connected through global networks with remote access services. It improves versatility between systems, yet it also increases the security risks for such environments.

This paper gives a basic overview of Industrial Network Security. It explains their common threats such as denial-of-service attacks. Later, discuss protection against them by methods and ends on standards and practices such as International Electrotechnical Commission (IEC) 62443 and Process Field Network (PROFINET).

Index Terms—Industrial network security, industrial control systems, IEC 62443, network segmentation, PROFINET, Cyber Resilience Act.

I. INTRODUCTION

The increasing integration of industrial communication systems with enterprise networks, remote access services, cloud platforms and Industrial Internet of Things (IIoT) applications has changed the security requirements of modern automation environments. Industrial networks are no longer used only as isolated communication infrastructures inside production plants. Instead, they increasingly connect programmable logic controllers (PLCs), human-machine interfaces (HMIs), sensors, actuators, engineering workstations and supervisory control and data acquisition (SCADA) systems with higher-level monitoring and management systems. Such communication structures exchange process data and control commands which are required for monitoring, coordination and control of physical operations [1].

In order for an industrial communication system to operate reliably, the communication between these components must remain available, correct and predictable. Industrial Network Security therefore refers to the protection of industrial communication infrastructures against unauthorized access, manipulation, disruption and misuse. Besides securing digital information, it also aims to keep industrial processes stable, predictable and safe. This makes security an essential requirement in industrial environments, because a cyber incident

can affect data and software systems as well as machines, production processes and human safety.

The growing connectivity of industrial systems improves flexibility, monitoring and efficiency, but it comes at the cost of exposing industrial systems to a larger attack surface. A successful cyberattack can lead to communication delays, incorrect process values, loss of monitoring, stopped production, equipment damage or even risks for human safety. Even a short interruption in communication between industrial devices, such as PLCs, HMIs, sensors and control systems, can have more serious consequences than a temporary service disruption in a typical office IT environment. For this reason, security in industrial networks is closely connected to availability, reliability and operational safety.

A major difference between traditional IT security and industrial or operational technology (OT) security is the priority of protection goals. In IT systems, data confidentiality is often the main focus, followed by integrity and availability. In industrial environments, availability and integrity are usually more critical, because control systems must operate continuously and with correct process data [1]. For example, a delayed control command or a manipulated sensor value can directly affect a physical process. In addition, industrial systems often have long life cycles, legacy devices, strict real-time requirements and limited possibilities for frequent updates or downtime. These characteristics make industrial network security more complex than applying standard IT security methods directly to the factory floor.

The focus of this paper is to provide an overview of important security aspects in industrial communication systems. First, common threats in industrial networks are discussed, including Denial-of-Service attacks, eavesdropping and Man-in-the-Middle attacks. Afterwards, methods for improving security, such as network segmentation, encryption and secure communication protocols, are considered. Finally, standards and best practices such as IEC 62443, the Cyber Resilience Act and PROFINET Security are introduced as guidance for

designing and maintaining secure industrial networks.

Responsible author: Umut Karakaya

II. COMMON THREATS IN INDUSTRIAL NETWORK SECURITY

A. Denial-of-Service attacks (DoS)

A whole class of attacks, named Denial-of-Service (DoS) attacks, attempts to degrade the availability and quality of communication services in a network. In industrial communication systems, this type of attack is especially critical because control and monitoring data must be exchanged continuously between devices such as PLCs, HMIs, SCADA servers, sensors and industrial switches. A DoS attack does not necessarily need to manipulate the actual process data in order to become harmful. It can already have a serious impact by delaying, blocking or overloading the communication channels used by legitimate industrial traffic. As a result, time-sensitive control messages may arrive too late, monitoring information may become unavailable or production processes may be interrupted. Similar to other communication infrastructures, DoS attacks therefore mainly target the availability of network resources [2].

In the context of industrial networks, DoS attacks can be caused by rogue nodes, compromised devices or unauthorized network components that generate abnormal traffic inside the communication infrastructure. Such components may send a large number of packets, malformed messages or unnecessary requests in order to occupy bandwidth, processing capacity or switch resources. If malicious or faulty traffic competes with critical industrial traffic for the same network path or device interface, legitimate communication can be forced to wait longer before reaching its destination. This is comparable to the way compromised elements in NoC-based systems can occupy communication resources and increase the forwarding delay of legitimate packets [2]. In an industrial environment, a similar situation can occur when an infected engineering workstation, a compromised gateway or an unauthorized device floods a network segment and prevents normal communication between control devices.

DoS attack avoidance focuses on reducing the probability that such traffic can affect critical industrial communication. One important approach is to separate critical and non-critical traffic by using network segmentation, security zones and controlled communication paths. Access control mechanisms should also ensure that only authorized devices are allowed to communicate with PLCs, HMIs and SCADA systems. In addition, traffic filtering, rate limiting and prioritization of time-critical packets can reduce the impact of abnormal traffic before it reaches sensitive parts of the network. For industrial systems, avoidance is especially important because recovery after a disruption may require production downtime or manual intervention. Therefore, secure network design should try to limit the ability of a single compromised device to influence the whole industrial communication system.

DoS attack detection and recovery are required when avoidance mechanisms are not sufficient. Detection can be

performed by monitoring unusual traffic patterns, packet rates, bandwidth usage, communication delays or repeated connection attempts [3]. If the observed behavior deviates strongly from the expected network behavior, the system can indicate a possible DoS attack. After detection, recovery mechanisms should aim to restore normal communication as quickly as possible. This may include isolating the suspicious device, blocking malicious traffic, rerouting communication over alternative paths or switching affected components into a safe state. In more advanced architectures, distributed monitoring can also help to localize the source of the attack and apply countermeasures close to its origin. This is important because simply detecting the presence of a DoS attack is not enough; the industrial network must also be able to maintain or recover the communication needed for a safe and reliable operation.

Responsible author: Umut Karakaya

B. Eavesdropping

Eavesdropping is one of the most critical threat in industrial network security. The word eavesdropping comes from the practice of standing beneath the eaves of a house to secretly listen to the conversations that going on inside [4].

Eavesdropping is the interception and access data transmitted over a network (such as phone call, message or videoconference) without authorization. With this attack, the enemy can make the network system vulnerable, monitor network traffic and capture sensitive data such as login credentials, financial data or proprietary business intelligence [4], [5].

Eavesdropping attacks can be both passive and active. In passive eavesdropping the attacker intercepts network traffic and monitor data transmissions without making any changes, on the other hand in active eavesdropping works in between to intercept and can alter the data before recipient receives it [4], [5].

Eavesdropping can be done by penetrate a company's Voice-over IP communications (VoIP) system, obtaining confidential details about future product releases and strategic plans. Bluetooth eavesdropping can be another way of attack where the attacker uses a high-gain antenna to intercept Bluetooth signals from attendees' devices during a conference [5].

Packet sniffing is another common way of attack that is done by using specialized software mostly effective when the data is transmitted without encryption. The impact of eavesdropping attack in industrial network can be huge. By this attack the enemy can leak trade secrets, research data, strategic plans and personal data of employees or customers. This can lead to damage of customer trust and also financial impact [5].

Responsible author: Md Mamun Hossain

C. Man-in-the-Middle attacks (MITM)

Man-in-the-Middle (MITM) is an attack where an attacker secretly takes control of the communication between devices. The attacker can intercept and modify data being transmitted between the hosts while being hidden from the victims [6].

MITM affects the CIA triad, compromising Confidentiality by eavesdropping on the communication, Integrity by

intercepting and modifying messages, and Availability by intercepting and destroying messages sent in the network [6].

Based on the attacker's interaction on the network, MITM can be divided into active and passive attacks [7]. In a passive attack, the attacker eavesdrops and analyses the network [7]. Meanwhile, in an active attack, the attacker directly tampers with the network [7]. MITM is a multi-layer threat, affecting multiple OSI layers of the network [6], [7].

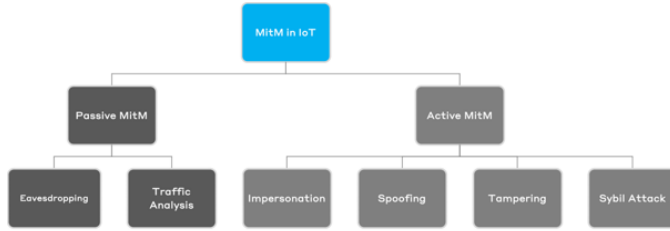


Fig. 1. Types of MITM, from [7].

The MITM attack has three major steps, which include reconnaissance, interception and traffic analysis and exploitation [7]. Once the communication channel between two hosts has been compromised, the attacker can manipulate or steal the transmitted data [7]. Several techniques can be used to implement an MITM attack [7], such as sniffing for interception and analysis of network traffic, packet injection for manipulating the network by injecting harmful packets, and session hijacking for stealing a host's session information to impersonate as the host [7]. The attacker can also use spoofing attacks to deceive the host by impersonating a legitimate source [7].

A spoofing attack is an impersonation of a device or user in the network by the attacker [6], which is used as an opening for other attacks, such as MITM [6]. Spoofing-based MITM is an attack where communication between two hosts is intercepted by the attacker using a spoofing attack, controlling the data being transmitted while remaining hidden from the hosts [6].

Responsible author: Sadim Rahman Badhan

III. METHODS FOR ENHANCING SECURITY

A. Network segmentation

Industrial networks are subjected to security threats, including but not limited to malware, ransomware, APTs and insider threats [8]. 2015's cyber attack on the Ukrainian power grid serves as a reminder of threats in the industrial networks [8]. Segmentation is a way of dividing a network into smaller, isolated segments to enhance security, performance, and manageability [9]. The importance of segmentation can be emphasised as the fundamental defence-in-depth strategy as it limits lateral movement by isolating sections of the network and applying specific security policies [9]. Micro-segmentation takes the concept of segmentation even further by isolating individual devices or workloads within the network [8], which enhances security even further. It ensures that once a host has been compromised, lateral movement within other hosts in the network is impossible for the attacker [8]. Studies have shown

that a zero-trust micro-segmentation framework reduced network exposure to vulnerabilities up to 90 percent, making it difficult for an attacker to take advantage of vulnerabilities present in the network [8].

Responsible author: Sadim Rahman Badhan

B. Encryption

Due to the number of devices connected to the network and the volume of data exchanged between these devices, data leakage, authentication and identification could be named as major security vulnerabilities in industrial and IoT devices [10]. This is significant when security analysts realise that 98 percent of all traffic among these devices is unencrypted [7], making it vulnerable to attacks such as MITM and traffic analysis. Traditional encryption schemes require significant computational overhead, memory and power, which industrial systems and IoT environments cannot often support [10]. Lightweight cryptography is specifically designed for devices with limited resources [10]. Over the last decade, several lightweight crypto primitives such as block cyphers, hash functions, stream cyphers and message authentication codes have been developed to improve performance over traditional cryptography [10]. While lightweight cryptography was designed for Industrial environments to operate with limited resources, its suitability is affected by its security weakness [10]. Many algorithms are vulnerable to cryptanalysis, which refers to the scientific study of cryptographic systems [10]. Therefore, its adoption must be carefully evaluated by ensuring resistance to cryptanalysis attacks, robust key management practices and compliance with industrial security standards, making it a feasible choice while implemented with hardened security measures [10].

Responsible author: Sadim Rahman Badhan

C. Secure protocols

Many industrial applications rely on traditional protocols such as Open Platform Communication Unified Architecture (OPC-UA) and modern protocols such as MQTT [11]. Using Transport Layer Security (TLS) or Datagram TLS (DTLS) ensures data transmission between devices, edge nodes and cloud platforms is secure and encrypted [11], which protects industrial data from unauthorised access and data breaches [11]. OPC-UA itself is a reliable and secure protocol widely used in legacy automation systems [11]. It also provides role-based access control, securing data from unauthorised access from insider threats [11]. Additionally, transmitting data through Virtual Private Networks (VPN), paired with multifactor authentication (MFA), enhances security, preventing eavesdropping and MITM attacks [5].

Responsible author: Sadim Rahman Badhan

IV. STANDARDS AND BEST PRACTICES

A. IEC 62443 Standard (Network Design, Vulnerability Handling Procedures)

Modern Industrial Automation and Control Systems (IACS) are strongly dependent on the connection between Information

Technology (IT) and network hardware components. While this link improves monitoring and control in systems, it also made them more vulnerable due to expanding the attack surface. To support security during the design phase, the IEC 62443 Standard was created to define general rules and guidelines [12].

In the standard, the design process starts with the identification of the System under Consideration (SuC). It includes the industrial assets, network components, software, and communication infrastructure [12].

After the workflow was defined, an initial cybersecurity risk assessment was performed. Based on this assessment, the system is divided into zones and conduits. During sectioning, it's considered data flows, functional specifications, physical or logical location, responsible organization, and required access. Therefore, IEC 62443 does not apply the same security measures to the whole industrial network but selects protection mechanisms according to the criticality and function of each part of the system [12], [13].

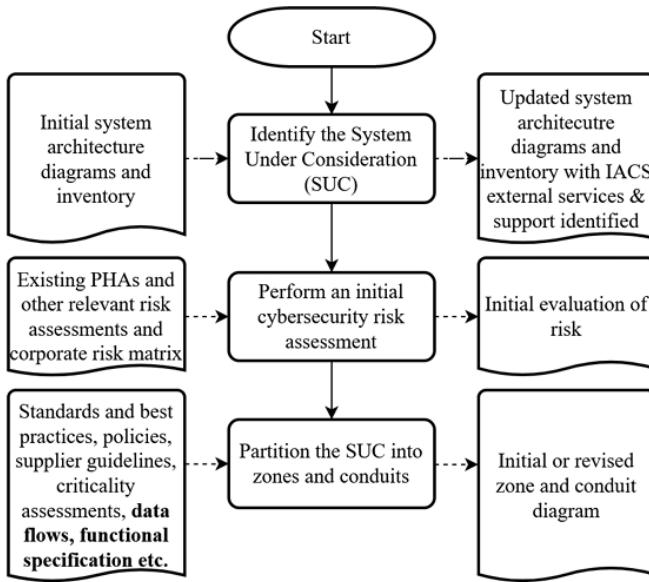


Fig. 2. Workflow to establish zones and conduits and assess risk, reproduced from [12].

For large-scale or complex systems, were created zones and conduits, which are identified within the SuC. They are the main elements by standard. A zone is a logical or physical group of industrial assets that share common security requirements (such as controllers, communication equipment, software applications). A conduit is a protected communication path between two or more zones. Therefore, there is a network segmentation, that limits unnecessary communication between assets, and helps to reduce the possibility that an attack can spread across the entire system at once [12].

Security levels in IEC 62443 are used to define how strong the protection of a zone or conduit should be. The standard distinguishes between the target security level, the achieved security level, and the capability security level. The target

security level describes the required protection, the achieved security level describes the current state of protection, and the capability security level describes whether the devices inside the zone are technically able to support the required security mechanisms [12], [13].

And finally, Vulnerability handling procedures in IEC 62443 security focuses on patch management. In industrial environments, vulnerabilities cannot always be fixed immediately, because updates may affect availability and slow the operation. Therefore, vulnerability handling should include a hand of updatable devices, records of installed software and firmware versions. These lists contains: regular checks for available updates, patch testing, scheduled installation, and compensating countermeasures when patches cannot be applied immediately [14].

Responsible author: Andrey Sysoev

B. Cyber Resilience Act (CRA)

The Cyber Resilience Act (CRA) is a European regulation aimed to improve cybersecurity by introducing a set of requirements for digital products. Its purpose is to make final goods are more secure before they enter the market [15].

The CRA also focuses on long-term vulnerability handling. Manufacturers are expected to work on and fix known vulnerabilities and provide security updates during the support period. This regulation revolves around the idea that security should be constant and maintainable in products. Therefore, the CRA support technical standards such as IEC 62443 by adding legal responsibility for secure issues of products [15].

Responsible author: Andrey Sysoev

C. PROFINET Security

PROFINET is a widely used Industrial Ethernet protocol for real-time communication in automation systems that can perform efficient data exchange between controllers and field devices [16].

The original design of PROFINET prioritized performance and real-time capabilities over security. As a result built-in protection mechanisms such as authentication, encryption or integrity verification are limited in PROFINET [16].

This makes PROFINET networks vulnerable to various cyber threats, including eavesdropping, unauthorized access, message manipulation and denial-of-service (DoS) attacks. In a research by Akerberg and Bjorkman found that industrial communication systems like PROFINET are especially vulnerable because of their increasing connectivity with enterprise IT networks and the Internet [16].

This connectivity expands the attack surface and exposes industrial environments to conventional IT-based threats. According to Walz et al., there can be three PROFINET security Classes (called Security Classes 1, 2 and 3) that classify the security capabilities of PROFINET components and tools [16]. Security Class 1 provides enhanced configuration features for network management (SNMP) and device discovery and configuration (DCP) protocols while security Classes 2 and 3 introduce built-in cryptographic protection of

PROFINET communication, that allow endpoints to establish secure PROFINET Application Relations (ARs) [17].

Generally cryptographic techniques are the combination of encryption, integrity protection, and authentication. These mechanisms focus to ensure that the data transmitted between devices is protected against unauthorized access and tampering. This makes secure communication channels which help safeguard both cyclic real-time data and acyclic communication traffic [17].

”Communication in an automation system needs to be upgraded with integrated security mechanisms, at least integrity protection, as for example described in IEC 62443-3-3 ” which promotes a Defense-in-Depth strategy. This strategy consists multiple layers of protection, such as network segmentation, secure device configuration, access control and continuous monitoring. Another PROFINET security can be the implementation of secure device identities and certificate-based authentication. These strategy ensure that only trusted devices can participate in network communication, which prevent unauthorized access and device spoofing attacks [17].

Responsible author: Md Mamun Hossain

V. CONCLUSION

Industrial network security is essential in modern Industrial Automation and Control Systems because they are constantly being exposed to cyber threats. Attacks such as denial-of-service, eavesdropping, and man-in-the-middle can affect availability and safe operation of industrial processes. Therefore, security is implied not only during working operation, but also during the design and maintenance phases.

In the end, secure communication protocols, encryption, and risk-based design help to reduce the vulnerabilities and limit possible attacks. Still, regular maintenance is necessary to keep industrial systems protected over time. As a result, security is treated as a continuous process with multiple steps and layers, which being described in different standards and protocols such as IEC 62443 and PROFINET.

Responsible author: Andrey Sysoev

Responsible author: Andrey Sysoev: paper structure, integration of individual sections, formatting, reference management, and final text revision.

REFERENCES

- [1] K. Stouffer, M. Pease, C. Tang, T. Zimmerman, V. Pillitteri, S. Lightman, A. Hahn, S. Saravia, A. Sherule, and M. Thompson, "Guide to Operational Technology (OT) Security," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST Special Publication 800-82 Rev. 3, 2023.
- [2] C. G. Chaves, S. P. Azad, J. Sepúlveda, and T. Hollstein, "Detecting and Mitigating Low-and-Slow DoS Attacks in NoC-Based MPSoCs," in *Proc. 2019 14th Int. Symp. Reconfigurable Communication-centric Systems-on-Chip (ReCoSoC)*, York, UK, 2019, pp. 82–89.
- [3] T. Cruz, J. Barrigas, J. Proença, A. Graziano, S. Panzieri, L. Lev, and P. Simões, "Improving Network Security Monitoring for Industrial Control Systems," in *Proc. 2015 IFIP/IEEE Int. Symp. Integrated Network Management (IM)*, Ottawa, ON, Canada, 2015, pp. 878–881.
- [4] U. Sehgal and K. Singh, "Eavesdropping Attack Problem Threat in Cyber Network Security and Wireless Sensor Network," *International Journal of Development Research*, vol. 7, no. 1, pp. 11 177–11 180, Jan. 2017.
- [5] Proofpoint, "What Is an Eavesdropping Attack?" 2026, accessed: Jun. 13, 2026. [Online]. Available: <https://www.proofpoint.com/us/threat-reference/eavesdropping>
- [6] M. Conti, N. Dragoni, and V. Lesyk, "A Survey of Man in the Middle Attacks," *IEEE Communications Surveys & Tutorials*, vol. 18, no. 3, pp. 2027–2051, 2016.
- [7] H. Fereidouni, O. Fadeitcheva, and M. Zalai, "IoT and Man-in-the-Middle Attacks," *Security and Privacy*, vol. 8, no. 2, 2025.
- [8] Z. T. Almulla and H. Rahman, "The Role of Network Segmentation and Micro-Segmentation in Operational Technology Security," in *Proc. 2025 Int. Conf. Artificial Intelligence in Information and Communication (ICAIIIC)*, Fukuoka, Japan, 2025, pp. 342–347.
- [9] R. Bredesen and S. Mujeye, "Network Segmentation Security with the Implementation of Threats," in *Proc. 2025 8th Int. Conf. Software Engineering and Information Management (ICSIM)*, 2025, pp. 137–141.
- [10] S. Khan, P. A. F. L. Martins, B. Sousa, and V. Pereira, "A Comprehensive Review on Lightweight Cryptographic Mechanisms for Industrial Internet of Things Systems," *ACM Computing Surveys*, vol. 58, no. 1, pp. 1–37, 2025.
- [11] V. D. P. Sai Guptha, S. Anamalamudi, R. P. Mandupuri, and S. Sivarajan, "Interoperability Between OPC-UA and MQTT in Hybrid Industrial IoT (IIoT) Environments," in *Proc. 2025 17th International Conference on COMMunication Systems and NETWORKS (COMSNETS)*, Bengaluru, India, 2025, pp. 1189–1194.
- [12] M. Kern, E. Taspolatoglu, F. Scheytt, T. Glock, B. Liu, V. Pazmino Betancourt, J. Becker, and E. Sax, "An Architecture-Based Modeling Approach Using Data Flows for Zone Concepts in Industry 4.0," in *Proc. 2020 IEEE Int. Symp. Systems Engineering (ISSE)*, 2020, pp. 1–8.
- [13] G. B. Gaggero, A. Armellin, P. Girdinio, and M. Marchese, "An IEC 62443-Based Framework for Secure-by-Design Energy Communities," *IEEE Access*, vol. 12, pp. 166 320–166 332, 2024.
- [14] M. Madsen, A. Palmin, A. Stutz, and M. Barth, "Security Analysis of the Module Type Package Concept," in *Proc. 2023 IEEE 21st Int. Conf. Industrial Informatics (INDIN)*, 2023, pp. 1–8.
- [15] European Commission, "Cyber Resilience Act," Shaping Europe's Digital Future, 2026, accessed: Jun. 16, 2026. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act>
- [16] J. Akerberg and M. Bjorkman, "Exploring Security in PROFINET IO," in *Proc. 2009 33rd Annu. IEEE Int. Computer Software and Applications Conf.*, Seattle, WA, USA, 2009, pp. 406–412.
- [17] A. Walz *et al.*, "PROFINET Security: A Look on Selected Concepts for Secure Communication in the Automation Domain," in *Proc. 2023 IEEE 21st Int. Conf. Industrial Informatics (INDIN)*, Lemgo, Germany, 2023, pp. 1–6.